

ISO 27002 – Guía de controles generales y perfil de especialistas

Guía de controles generales

En la Seguridad informática los controles se clasifican en:

Tipos de controles de acceso

- Administrativos: incluye políticas y procedimientos definidos por la organización.
- Controles lógicos y técnicos: controles que requieren mecanismos de *soft* y *hard*.
- Controles físicos: barreras físicas para evitar el contacto con los sistemas.

Categorías de controles

- Preventivos: tratan de evitar un hecho.
- Detectivos: buscan anunciar cuanto antes la aparición de un evento.
- Correctivos: facilitan la vuelta a la normalidad cuando se ha producido una incidencia.
- Disuasivos: inhiben.

(5) Política de seguridad de la información

Políticas generales	
Proporcionar dirección gerencial y apoyo a la seguridad de la información de forma acorde a los requerimientos comerciales y a las leyes y regulaciones relevantes	• Documentar la política de seguridad de la información • Revisión continua y puntual de la política de seguridad de la información

Figura 1: Anexo A – ISO 27002 (5). Fuente: elaboración propia.

(6) Organización de la seguridad de la información

Organización interna	
Gestionar la seguridad de la información dentro de la organización	• Compromiso de la dirección con la seguridad de la información • Coordinación de la seguridad de la información • Asignación de responsabilidades con respecto a la seguridad de la información • Proceso de autorización para los medios de proceso de la información • Acuerdos de confidencialidad • Contacto con las autoridades • Contacto con grupos de interés especial • Revisión independiente de la seguridad de la información
Entidades externas	
Mantener la seguridad de la información y los medios de proceso a los que tienen acceso, procesan o son comunicados por entidades externas	• Identificación de riesgos relacionados con entidades externas • Tratamiento de la seguridad en relación a los clientes • Tratamiento de la seguridad en contratos con terceros

Figura 2: Anexo A – ISO 27002 (6). Fuente: elaboración propia.

(7) Gestión de los activos

Responsabilidad sobre los activos	
Conseguir y mantener la protección apropiada de los activos de la organización	• Inventario de activos • Propiedad de los activos • Uso aceptable de los activos
Clasificación de la información	
Garantizar que la información reciba un nivel de protección apropiado	• Criterios de clasificación • Etiquetado y manejo de la información

Figura 3: Anexo A – ISO 27002 (7). Fuente: elaboración propia.

(8) Seguridad de los recursos humanos

Previamente al desempeño	
Asegurar que los empleados, contratistas y terceros entiendan sus responsabilidades y sean adecuados para los roles considerados	- Definición de roles y responsabilidades - Realización de los procesos de selección - Existencia y aceptación de términos y condiciones del empleo con respecto a la seguridad
Durante el desempeño	
Asegurar que los empleados, contratistas y terceros conozcan las amenazas sobre los activos, sepan sus responsabilidades y apoyen la política de seguridad	- Gestión de responsabilidades - Capacitación y formación en seguridad de la información - Procesos disciplinarios
Terminación	
Asegurar la salida de forma ordenada de empleados, subcontratistas o terceros	- Responsabilidades - Devolución de los activos - Eliminación de los derechos de acceso

Figura 4: Anexo A – ISO 27002 (8). Fuente: elaboración propia.

(9) Seguridad física y ambiental

Áreas seguras	
Evitar el acceso no autorizado, daños o interferencias al local y a la información de la organización	- Existencia de un perímetro de seguridad física - Existencia de controles de entrada físicos - Seguridad de oficinas, locales y medios - Protección frente a amenazas externas y ambientales - Trabajo en áreas seguras - Normativas de uso de áreas de acceso público, puntos de entrega y carga
Seguridad de los equipos	
Evitar la pérdida, daño, robo o compromiso de los activos y la interrupción de las actividades de la organización	- Ubicación y protección de los equipos - Garantía de disponibilidad de los servicios públicos necesarios - Seguridad en el cableado - Políticas de actualización y mantenimiento de los equipos - Seguridad de los equipos ubicados fuera del local - Baja y/o reutilización de los equipos - Cambios de propiedad de los equipos

Figura 5: Anexo A – ISO 27002 (9). Fuente: elaboración propia.

(10) Gestión de comunicaciones y operaciones

Procedimientos y responsabilidades operacionales	
Asegurar la operación correcta y segura de los medios de proceso de la información	• Documentación de los procedimientos de operación • Metodología de gestión de los cambios • Separación de responsabilidades • Separación de los medios de desarrollo y productivos
Gestión de la prestación del servicio por parte de terceros	
Mantener el nivel de seguridad adecuado en línea con los SLA	• Implementación, realización y mantenimiento por parte de los terceros de los niveles de seguridad requeridos por la organización • Monitorización y revisión de los servicios prestados • Procedimientos de cambios en los servicios prestados por terceros
Planificación y aceptación de los sistemas	
Minimizar el riesgo de errores	• Gestión de la capacidad • Procesos de aceptación
Protección contra código malicioso	
Proteger la integridad del software y de la información	• Controles contra el software malicioso • Controles contra códigos móviles
Respaldo	
Mantener la integridad y disponibilidad de los servicios	• Existencia y realización de copias de seguridad de los sistemas de forma acorde a los niveles de seguridad requeridos
Gestión de la seguridad de las redes	
Asegurar la protección de la información en las redes y de la infraestructura de soporte	• Existencia de medios de gestión y control de las redes • Seguridad de los servicios de red, propios o prestados por terceros
Gestión de los medios	
Evitar la exposición, modificación, eliminación o destrucción no autorizada de los activos	• Gestión de los medios removibles • Normativa de eliminación de medios • Procedimientos de gestión de la información • Seguridad de la documentación del sistema
Intercambio de información	
Mantener la seguridad en los intercambios dentro de la propia organización y con terceros	• Procedimientos y políticas de intercambio de información y de software • Existencia de acuerdos de intercambio • Protección de los medios físicos de tránsito, de los mensajes electrónicos y de los sistemas comerciales

Servicios de comercio electrónico	
Garantizar la seguridad de los servicios de eCommerce y su correcta utilización	• Protección del comercio electrónico • Protección de la información de las transacciones online • Protección de la información de acceso público
Monitorización	
Detectar actividades de acceso o proceso no autorizadas	• Registro de auditoría • Uso del sistema de monitorización • Protección de las informaciones de seguimiento • Registros de la actividad del administrador y del operador • Registro de incidencias • Mecanismos de sincronización de los relojes

Figura 6: Anexo A – ISO 27002 (10). Fuente: elaboración propia.

(11) Control de acceso

Requisitos	
Controlar el acceso a la información	• Política de control de accesos
Gestión del acceso del usuario	
Evitar accesos no autorizados a los sistemas de información	• Procedimientos de alta y baja de usuarios y derechos de acceso • Gestión de privilegios • Gestión de las palabras de paso • Revisión periódica de los derechos de acceso
Responsabilidades del usuario	
Evitar la exposición, robo y/o acceso no autorizado	• Políticas de empleo de palabras de paso • Políticas de seguridad de equipos desatendidos • Normativas de puestos de trabajo despejados
Control de acceso a redes	
Evitar accesos no autorizados a los recursos de red	• Política sobre el empleo de los servicios de red • Autenticación de los usuarios para realizar conexiones externas • Identificación del equipo en red • Protección del puerto de diagnóstico remoto • Segregación de las redes • Control de conexión a las redes • Control del encaminamiento en las redes
Control de acceso al sistema productivo	
Evitar el acceso no autorizado a los sistemas de producción	• Procedimientos de registro en el puesto de trabajo • Mecanismos de identificación y autenticación • Sistema de gestión de las palabras de paso • Restricciones de uso de las utilidades del sistema • Cierre de sesiones inactivas • Limitación del tiempo de conexión

Control de acceso (cont.)

Equipos portátiles y teletrabajo	
Garantizar la seguridad cuando se empleen esos medios	• Políticas y normativas de uso de los equipos portátiles • Políticas, planes y procedimientos para actividades de teletrabajo
Control de acceso a las aplicaciones y a la información	
Evitar accesos no autorizados a sistemas y datos	• Restricción de los accesos de los usuarios a los procesos e información necesarios para el desempeño de su trabajo • Aislamiento de sistemas que manejen información sensible

Figura 7: Anexo A – ISO 27002 (11). Fuente: elaboración propia.

(12) Adquisición, desarrollo y mantenimiento de los sistemas de información

Requerimientos de seguridad de los sistemas	
Garantizar que la seguridad sea parte integral de los sistemas	• Análisis y especificaciones de los requerimientos de seguridad de los sistemas
Proceso correcto de las aplicaciones	
Evitar errores, pérdidas, modificaciones no autorizadas o mal uso de la información por parte de las aplicaciones	• Validación de las fechas de entrada y de la información • Existencia de control interno en los procesos • Requerimientos y medios de protección de los mensajes proporcionados por las aplicaciones • Comprobación de fechas y datos de salida de los procesos
Controles criptográficos	
Proteger la confidencialidad, autenticidad e integridad de la información por medio de procesos de cifrado	• Políticas de uso de controles criptográficos • Gestión de las claves
Seguridad de los archivos del sistema	
Garantizar la seguridad de los archivos del sistema	• Control del software en operación • Protección y control de los datos de prueba • Control de acceso al código fuente de los programas
Seguridad de los procesos de desarrollo y soporte	
Mantener la seguridad del software y datos de las aplicaciones	• Procedimientos de control de cambios • Revisiones técnicas de funcionamiento tras cambios en los sistemas operativos • Medios para evitar filtraciones de información • Medios del control del software desarrollado externamente
Gestión de la vulnerabilidad técnica	
Reducir los riesgos derivados de la explotación de vulnerabilidades publicadas	• Control de vulnerabilidades técnicas • Valoración de los niveles de exposición a los riesgos asociados y aplicación de las medidas correctivas adecuadas

Figura 8: Anexo A – ISO 27002 (12). Fuente: elaboración propia.

(13) Gestión de incidentes en la seguridad

Identificación de incidentes en la seguridad de la información	
Asegurar que la información de estos eventos se comunique de forma que sea posible tomar acciones correctivas de forma oportuna	• Comunicación de los incidentes de seguridad a nivel interno y externo • Existencia de medios y canales para la recopilación de las incidencias de seguridad
Gestión de incidentes en la seguridad de la información	
Garantizar que se aplique un enfoque consistente y efectivo a la gestión de la seguridad	• Asignación de responsabilidades y desarrollo de procedimientos de respuesta rápida, efectiva y ordenada • Mecanismos de cuantificación y monitorización de tipos, afectación y coste de los incidentes de seguridad • Recopilación de evidencias

Figura 9: Anexo A – ISO 27002 (13). Fuente: elaboración propia.

(14) Gestión de la continuidad comercial

Aspectos de seguridad	
Contrarrestar la interrupción de la actividad y proteger los procesos críticos en caso de fallos o desastres	• Inclusión de la seguridad de la información en el proceso de gestión de la continuidad comercial • Evaluación de los riesgos • Desarrollo e implantación de planes de continuidad que incluyan la seguridad de la información • Mantenimiento de un único marco referencial para la continuidad • Prueba, mantenimiento y actualización periódica de los planes de continuidad

Figura 10: Anexo A – ISO 27002 (14). Fuente: elaboración propia.

(15) Cumplimiento legal y normativo

Con requerimientos legales	
Cumplir la legislación, obligación reguladora o contractual y cualquier requisito de seguridad	• Identificación de la legislación aplicable • Derechos de propiedad intelectual • Protección de los registros y archivos de la organización • Protección de datos y privacidad de la información personal • Prevención del mal uso de los medios de proceso • Regulación de los controles criptográficos
Con las políticas y estándares de seguridad	
Garantizar que se cumplen las normas de seguridad de la propia organización	• Aseguramiento de cumplimiento interna de las políticas y estándares de seguridad • Comprobación del cumplimiento técnico
Consideraciones de auditoría	
Maximizar la efectividad y minimizar la interferencia de/desde auditoría	• Determinación de los controles de auditoría de los sistemas • Protección de las herramientas de auditoría de los sistemas de información

Figura 11: Anexo A – ISO 27002 (15). Fuente: elaboración propia.

Perfil de especialistas

Las responsabilidades de un especialista en seguridad informática deben:

- Concebir e implementar una arquitectura de seguridad y control homogéneo y estándar.
- Implementar los procesos que permitan preservar la integridad, disponibilidad y confidencialidad de la información.
- Administrar las medidas de seguridad informática y el acceso a la información y a los recursos informáticos.
- Propender una administración de la seguridad lógica centralizada, logrando simplificar el acceso de los usuarios a las distintas plataformas.
- Desarrollar e implementar las políticas, normas y procedimientos de seguridad informática.
- Realizar la evaluación de riesgos propios de los ambientes tecnológicos cuya seguridad administra y/o controla.
- Analizar e implementar, en conjunto con las áreas técnicas, nuevas medidas de seguridad.

- Evaluar el impacto, desde el punto de vista de seguridad, de la implementación de nuevas tecnologías y/o aplicaciones.
- Brindar asesoramiento y soporte técnico en temas vinculados a la seguridad informática.
- Establecer las técnicas de control y evaluación de incidencias que puedan afectar a la seguridad informática.
- Conducir la investigación de incidentes relacionados con la seguridad informática.
- Participar como miembro activo del equipo de contingencia informática.
- Administrar los procedimientos sobre las claves de encriptación.
- Fomentar la coordinación entre distintas áreas a fin de lograr un adecuado nivel de seguridad informática.
- Establecer los planes de formación y capacitación sobre medidas de seguridad informática.
- Planificar y presupuestar las inversiones en temas relativos a la seguridad informática.
- Interacción con la Organización la función de Seguridad Informática tendrá una estrecha relación con todas las áreas de la organización dado que debe:
- Satisfacer los requerimientos de acceso a la información.
- Asesorar sobre la administración de aspectos de seguridad en poder de los usuarios.

Referencias bibliográficas

- CISSP Sixth Edition – Shon Harris Mc Graw Hill
- En español: <http://www.iso27000.es/>
- En inglés: <http://www.iso27001security.com/>
- ISO/IEC 27000 en iso.org: <https://www.iso.org/obp/ui/#iso:std:iso-iec:27000:ed-3:v1:en>